DOCUMENT

11

Operations and Security

Controls, limits, follow-up work and release notes

The app is a demo: in-memory, single process, demo accounts. This document says what it guarantees, what it does not, and what is left to do before any real use.

1. Running it

Aspect	Detail
Start	`python -m uvicorn invoice_app.api.main:app --app-dir backend/src --port 5000`
Configuration	None. Demo users and seed invoices are in code
State	In memory. Restart resets everything
Processes	Designed for one process. The approval lock and the session store are per-process
Health	Opening `/` serves the UI; `/docs` serves the OpenAPI page

2. Seed data

Invoice	Customer	Amount	Status
INV-1001	Lakeside School District	4,250.00	Pending
INV-1002	Hilltop Academy	980.50	Pending
INV-1003	Riverside Charter	12,300.00	Approved
INV-1004	Oakwood Independent	615.75	Pending
INV-1005	Maple Grove Prep	310.00	Draft
INV-2001	Summit Unified District	75,000.00	Pending (needs a Director)
INV-2002	Ridgeview Education Consortium	600,000.00	Pending (needs two approvers)

3. Security controls in place

Control	Detail
Authentication	Bearer token required on every `/api` route except login
Authorization	`require_role` at the router; the domain is the single authority on who may approve
Fail closed	Unknown or mistyped roles cannot approve
No side effects on refusal	All checks run before the first mutation
Race safety	One lock around submit, approve and reject; verified by tests that fail without it

Control	Detail
Input validation	Amount: greater than zero, at most 2 decimals, at most 12 integer digits; customer name required
Error hygiene	500 responses carry no detail; validation errors do not echo internals; only `DomainValidationError` maps to 400
Secrets	None in the repository. Demo passwords are labelled as demo credentials

4. Known limitations

Limitation	Impact
Sessions never expire (finding F11, deferred as T025)	A leaked token stays valid until restart
Passwords compared with `==`, not constant-time; no login throttling (F11)	Acceptable for a local demo, not for production
Create and submit are open to every signed-in role (dismissed F10)	Same as the original app; approval authority is what the feature restricts
In-memory repository returns live objects	Safe today because every service path checks first and holds the lock; a real database needs a row lock or version column
No audit of refused attempts	A refusal leaves no record by design ("changes nothing"); add logging outside the invoice if auditing refusals is required
`float` in JSON	Amounts are limited to 12 integer digits plus 2 decimals, which doubles represent exactly to the cent
Single process	Two server processes would not share the lock or sessions

5. Before production

1. Replace the in-memory repository with a database; use row locking or an optimistic version for approvals.
2. Replace demo users with real identity and short-lived sessions or tokens; add constant-time comparison and throttling (T025).
3. Decide whether refused attempts must be audited, and where.
4. Add a reset or test-data endpoint for end-to-end tests only, guarded by configuration (T024).
5. Add structured request logging and metrics.

6. Deferred work

Id	Item	Source
T024	Second Playwright spec for the two-Director flow, with a reset endpoint so mutating UI tests are repeatable	Review finding F7
T025	Session expiry and constant-time password comparison	Review finding F11
T022	Record the demo video and add the link to `ASSIGNMENT.md`	Assignment
T023	Commit in steps, push to the fork, open the PR	Assignment

7. Release notes

Version of this delivery: approval limits by role

- New: Manager limit 50,000.00; Director limit 500,000.00; two distinct approvers above that with a Director second; refusal returns 403 with a specific reason and changes nothing.
- New: `requiredApprovals` and `approvals` on the invoice JSON; "N of M approvals" in the UI.
- New demo accounts `demo.manager`, `demo.director`, `demo.director2`; seed invoices INV-2001 and INV-2002.
- Changed: legacy `Approver` role replaced by `Manager`; `Admin` can no longer approve.
- Changed: invalid amounts (`1e999999`, NaN, sub-cent, too large) now return 400 and are not stored.
- Changed: unexpected errors return 500 without detail; only domain validation errors return 400.
- Changed: the backend is now Python (FastAPI); behaviour of the original endpoints is unchanged.